MULTI-CLOUD FDE STACK #04

MULTI-CLOUD FDE STACK · ISSUE 04 OF 08

Secrets: one pattern, three vaults.

Secrets Manager, Secret Manager and Key Vault.

04

AR

Akhilesh Ranjan Singh

Senior DevSecOps Engineer · github.com/iarsingh

Swipe →

The three vaults

SERVICE	WORTH KNOWING
AWS Secrets Manager	Built-in rotation, managed for RDS
GCP Secret Manager	Versions + rotation reminders via Pub/Sub
Azure Key Vault	Secrets, keys and certs; use RBAC mode

AR
Akhilesh Ranjan Singh
github.com/iarsingh

Into the pod, no keys

1. Workload identity
2. CSI driver or External Secrets
3. Mounted file
4. App re-reads on failure

> Files can update on rotation. Environment variables cannot, and they leak into crash dumps.

AR
Akhilesh Ranjan Singh
github.com/iarsingh

Rotation without downtime

01 Two valid credentials

Create the new one while the old still works.

02 Re-read on auth failure

Not only at startup.

03 Confirm in logs

Nothing still uses the old credential.

04 Then revoke

And record when and who.

AR
Akhilesh Ranjan Singh
github.com/iarsingh

Secret hygiene

DO

- ✓ One secret per purpose
- ✓ Audit log reviewed
- ✓ Soft delete and purge protection
- ✓ Rotation rehearsed in staging

AVOID

- ✗ Secrets in Git or images
- ✗ Secrets in logs or traces
- ✗ One shared admin password
- ✗ Rotation as a launch-day surprise

AR
Akhilesh Ranjan Singh
github.com/iarsingh

Secrets review

- [x] No static cloud keys
- [x] Secrets mounted as files
- [x] Rotation tested end to end
- [x] Access scoped per workload
- [x] Break-glass path documented

AR
Akhilesh Ranjan Singh
github.com/iarsingh

KEY TAKEAWAY

A secret you have never rotated is a secret you cannot rotate.

→ Use workload identity to reach the vault

→ Re-read secrets, do not cache forever

→ Rehearse rotation before go-live

YOUR TURN

When did you last rotate a production database password?

FOLLOW AKHILESH RANJAN SINGH

Next in the series: #05 SQS, Pub/Sub, Service Bus

Save · Repost

AR
Akhilesh Ranjan Singh
github.com/iarsingh